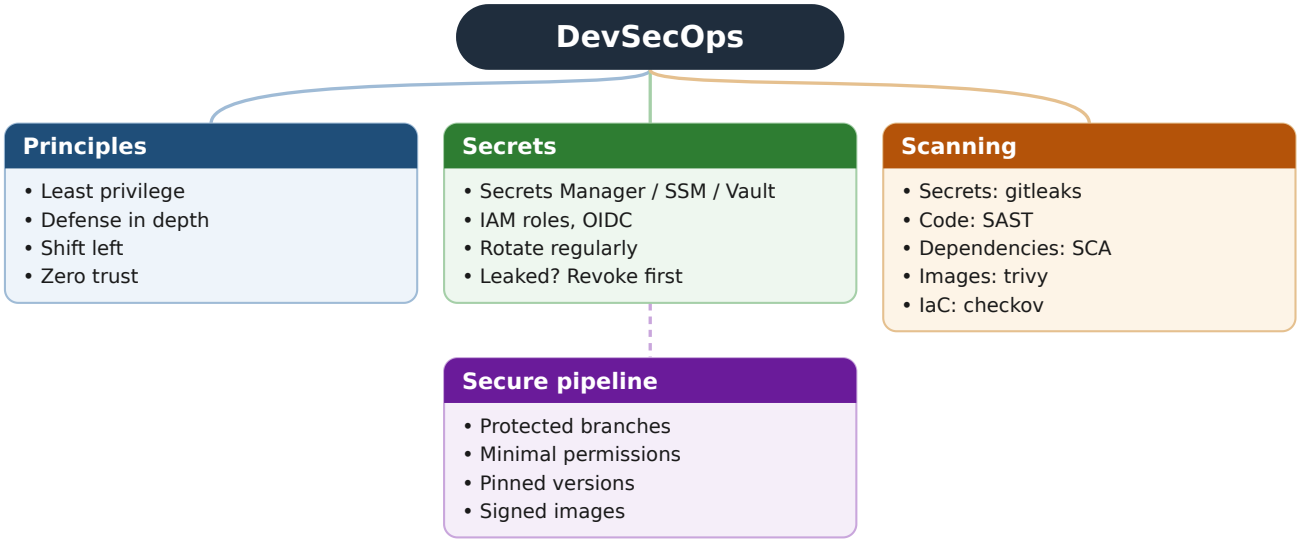
14. DevSecOps (Security Throughout)

In this section: 14.1 Principles · 14.2 Secrets management · 14.3 Security scanning in the pipeline · 14.4 Secure CI/CD · 14.5 Security checklist by layer



14.1 Principles

Principle	Meaning
Least privilege	Every user, service and pipeline gets only the permissions it needs
Defense in depth	Several layers of protection, so one failure isn't fatal
Shift left	Find security problems early (in code and PRs), not in production
Zero trust	Never trust by network location; always authenticate and authorize
Immutable infrastructure	Replace servers/containers instead of patching them by hand

14.2 Secrets management

- Never hardcode secrets or commit them (`.env`, keys, tokens, `.tfstate`).
- Store them in AWS Secrets Manager, SSM Parameter Store, HashiCorp Vault, or CI secret stores.
- Prefer short-lived credentials: IAM roles, OIDC for CI, IRSA/Pod Identity for Kubernetes.
- Rotate secrets. If one leaks, **revoke it first**, then clean up.

14.3 Security scanning in the pipeline

Scan	What it finds	Tools
Secret scanning	Passwords/keys in code and history	gitleaks, GitHub secret scanning, trufflehog
SAST	Insecure code patterns	Semgrep, CodeQL, SonarQube

Scan	What it finds	Tools
Dependency scanning (SCA)	Libraries with known vulnerabilities (CVEs)	Dependabot, `pip-audit`, `npm audit`, Trivy
Container image scanning	Vulnerable OS packages and libraries in images	Trivy, Grype, ECR scanning
IaC scanning	Insecure Terraform/K8s config (open SGs, public buckets)	Checkov, tfsec/Trivy config, kube-linter
DAST	Vulnerabilities in the running app	OWASP ZAP
SBOM	List of everything inside an image/app	Syft, Trivy

14.4 Secure CI/CD

- Protected branches: PR review + required status checks.
- Minimal pipeline permissions; OIDC instead of long-lived cloud keys.
- Pin actions/plugins/images to versions; keep Jenkins and plugins updated.
- Separate deploy credentials per environment; approvals for production.
- Fail the build on critical vulnerabilities and on leaked secrets.
- Sign images (cosign) and only deploy trusted images.

14.5 Security checklist by layer

Layer	Must do
Accounts / IAM	MFA, no root use, roles over keys, least privilege, CloudTrail on
Network	Private subnets for apps/DBs, tight SGs, no 0.0.0.0/0 on SSH/DB ports, TLS everywhere
Servers	Patched, SSH keys only, no root login, firewall, minimal packages
Containers	Non-root, minimal pinned images, scanned, no secrets inside
Kubernetes	RBAC, NetworkPolicies, Pod Security, secrets encryption, limits
Data	Encryption at rest (KMS) and in transit (TLS), backups tested
Code / pipeline	Scans, reviews, signed artifacts, secrets in a manager

REMEMBER

- Never in Git: **passwords, keys, tokens, .env files, tfstate**.
- Security is every layer: IAM → network → server → container → Kubernetes → data.